[文章标题]

ROV++: Improved Deployable Defense against BGP Hijacking

——2021 NDSS

[研究背景与动机]

边界网关协议(BGP)是互联网的核心域间路由协议，但是由于设计之初未包含认证机制，这一缺陷使其长期面临着路由劫持攻击的风险，特别是子前缀劫持(subprefix hijacks)和未路由前缀劫持(non-routed prefix hijacks)。对此，标准化的防御机制是路由源验证(Route Origin Validation, ROV)。

然而，本论文指出，在部署不完全的情况下，ROV 对这些主要攻击的防护效果有限。此外，ROV 还会引发隐藏劫持，即路由表路径正确，但实际数据流却被劫持的现象。尤其对以下两种攻击：

1. 子前缀劫持：攻击者宣告一个合法前缀的子前缀。由于 BGP 默认选择最长前缀匹配，即使部署了 ROV 的 AS，其流量也可能通过未部署 ROV 的上游 AS 被劫持。更糟糕的是，ROV 甚至会隐藏这种劫持，使得受害 AS 在控制平面（路由表）上看不到异常，但数据流量却被悄无声息地导向了攻击者，形成 隐藏劫持。
2. 非路由前缀劫持与超级前缀劫持：攻击者宣告一个未被使用的“幽灵”前缀（常用于发送垃圾邮件或 DDoS），或者宣告一个包含目标非路由前缀的超级前缀。对于后者，由于超级前缀本身可能没有对应的 ROA，ROV 将允许其传播，从而完全绕开 ROV 的防御。

因此，论文的研究动机是：在 ROV 部分部署将长期存在的前提下，设计一种能够提供更强安全保证、尤其是能有效防御数据平面劫持的、容易部署的增强机制。

[主要贡献]

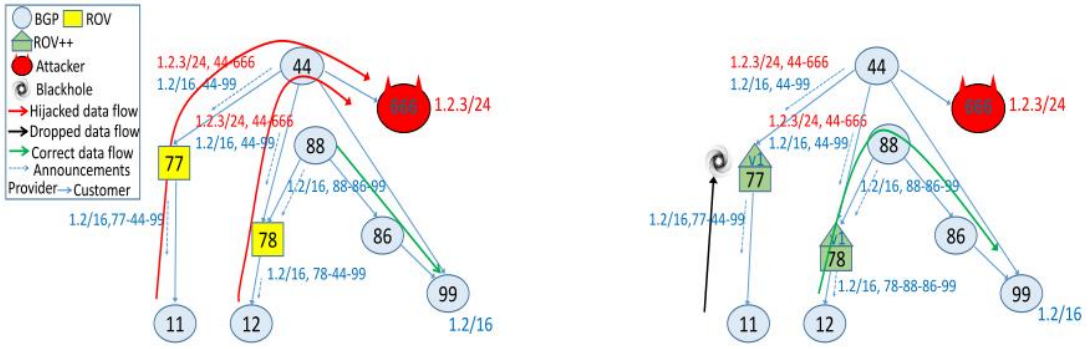
论文系统性地揭示了 ROV 在部分部署下的根本性缺陷，明确指出了数据平面劫持和隐藏劫持的概念与危害，并首次提出了超级前缀劫持这一能完全绕过 ROV 的新型攻击。在此前提下，提出了 ROV++系列增强机制，并为此设计了三种渐进式的 ROV++版本（v1, v2, v3），通过偏好安全路径、本地黑洞、黑洞通告和预防性通告等机制，显著提升了在部分部署场景下的防御能力。

此外，基于真实的互联网 AS 拓扑，进行了全面且大规模的仿真评估。对 ROV 和各种 ROV++变体进行了仿真结果表明，即使在很低的部署率下（如 5%），ROV++也能将边缘 AS 受子前缀劫持的比例从 ROV 的 95%以上降低到 10%以下，效果提升显著。

在 ROV 采用率较低的情况下,进一步开发和评估了 ROV++ Lite 版本，它可以轻松部署在现有路由器上，而无需修改 BGP 路由选择进程，极大地降低了部署门槛。性能评估显示 Lite 版本性能与非 Lite 版本非常接近。

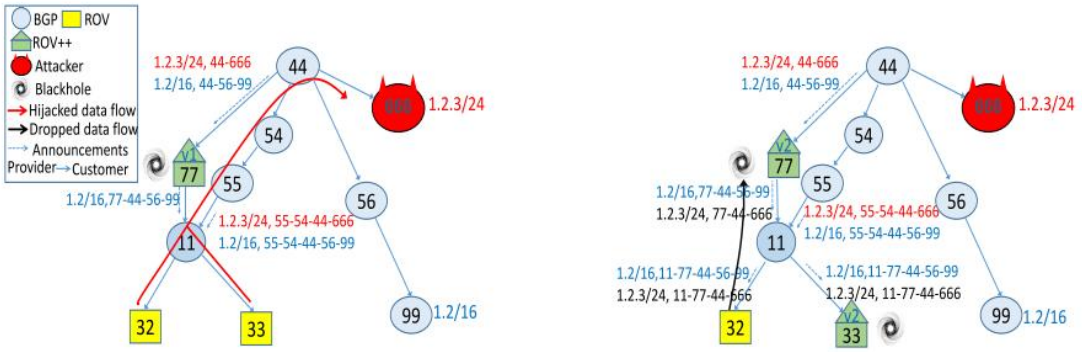
[解决思路与方案]

为了解决 ROV 在部分部署的场景下安全防护效果不足的问题，本文提出并设计了增强型防御机制 ROV++，其中包含三个逐步增强的变体 v1/v2/v3 及 Lite 软件化实现，其基本思路是在保留 ROV 验证的同时增加三个核心机制：



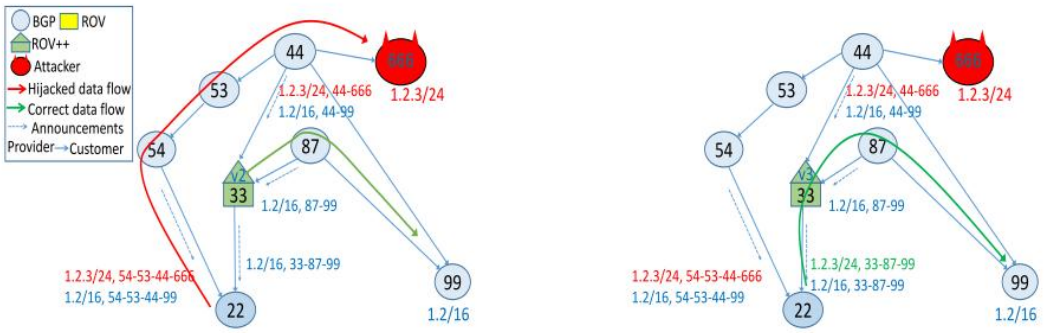
(a) (b)

（1）v1:是通过检测路由“空洞”（Hole）实现，即当来自同一邻居的合法前缀公告与无效子前缀公告并存时，意味着经由该邻居的对应子前缀流量将被劫持。v1 将优先选择无“空洞”的安全路径；若不存在此类路径，则对受影响子前缀执行黑洞处理，从而彻底避免流量被攻击者窃听或中转。



(a) (b)

（2）v2:在 v1 基础上，当本地黑洞不足以保护下游时，向下游发出黑洞公告，把流量吸引到能被安全丢弃的位置，保护它们免受劫持。

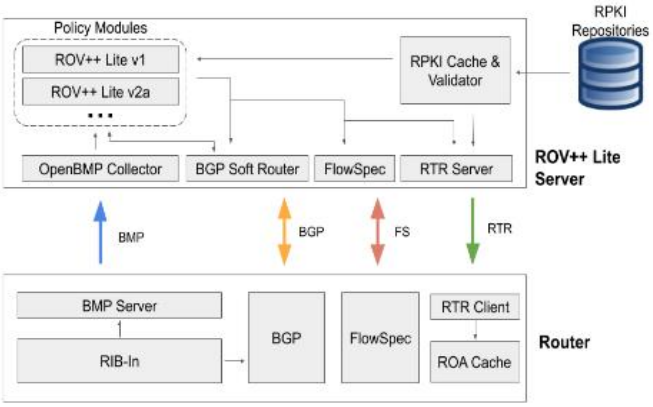


(a) (b)

（3）v3：在 v2 基础上，v3 会主动发出预防性公告，用合法路径信息与攻击的子前缀竞争，尝试将流量引导至合法源，以提升成功到达合法源的概率。

评估方法：本文实现了一个 BGP 仿真器，并使用 2020 年 CAIDA 的 AS 拓扑数据，做了 2000+次的大规模模拟。

在此基础上，论文进一步提出了 ROV++的 Lite 版本，一种纯软件方案，可以基于现有路由器上的标准机制部署，大幅降低了部署门槛。



文章还进行了进一步的分析和实验测试，结果表明：
（1）在 5%采用率的情况下，采用 ROV 的边缘 AS 中约 95%仍会遭受子前缀劫持，而采用 ROV++的边缘 AS 中只有 5%遭受劫持。证明 ROV++对边缘 AS 都有显著的安全防护效果。
（2）在面对非路由前缀的超前缀攻击时，ROV++通过其黑洞机制能够实现完全防御，而 ROV 无法阻止此类攻击。
（3）ROV++的 Lite 版本在性能上与其非 Lite 版本几乎相同，进一步验证了该方案的实用价值。

[不足之处]
（1）本文中的假设偏理想化，如完全遵循谷自由路由、无 ROA 配置错误等，与现实情况不符，在实际场景下 ROV++的效果仍需进一步验证。
（2）ROV++ v1 和 v2 在没有安全路径时采用黑洞处理，虽然避免了流量被攻击者劫持，但也牺牲了部分网络的可达性。
（3）虽然 ROV++显著降低了劫持率，但仍然存在隐藏劫持的现象，这表明 BGP 控制平面与数据平面不一致的问题并未被彻底消除。

[个人思考]
本文属于路由安全与防御机制类研究，文章内容扎实、分析细致，从现实的角度出发，重新思考路由安全机制。针对 BGP 安全协议在部分部署这一现实情况下的局限性，作者并未沿用传统 RPKI ROV 的研究思路，而是将设计重心巧妙地放在 ROV 低采用率下仍能显著提升安全效益上，以此来设计增强型防御机制。

个人认为这是在 BGP 安全领域最贴近实际应用场景的方案之一，其写作逻辑、实验严谨性、以及对部署现实的考量都值得参考。但仍存在一些考虑不周之处：首先并没有量化黑洞机制带来的可用性问题，部分情况下可能导致丢弃合法流量；此外，预防性公告 v3 存在被滥用的潜在风险，没有签名机制可能会与未来的 BGPsec 冲突。上述这些问题虽不影响论文的主要贡献，但是无论是后续的研究还是实际部署都需要进一步考虑上述不足。

基于 ROV++的成果和局限性，我认为未来的研究和改进方向可以集中在以下几点：

- ROV++当前与 BGPsec 并行，未来可研究两者的融合，降低滥用风险；
- ROV++的 hole 检测与黑洞策略基于静态规则，未来可以引入机器学习或基

于异常检测的机制，让系统根据历史流量模式动态调整策略；

- 黑洞公告在局部范围内有效，但缺乏跨域协调，未来可以设计轻量级的威胁通告协议，使多个 ROV++节点共享攻击者信息。

总而言之，本文不仅是对 ROV 机制的重要改进，更是为未来互联网路由安全的研究与实践提供了有价值的思路和工具。但其中涉及的黑洞与预防公告在提升安全性的同时，也可能带来的网络可达性下降与潜在滥用风险，这些问题仍需进一步的研究验证。